

ĐỀ CƯƠNG PROJECT 1 – E15 - 20252

1. Mục tiêu đạt được

- Nhận diện và thực hành khai thác các lỗ hổng OWASP Top 10 trên các ứng dụng thực tế.
- Thành thạo việc sử dụng các công cụ bảo mật tự động: SAST (Semgrep, SonarQube), SCA (Snyk), DAST (OWASP ZAP).
- Tự tay xây dựng được DevSecOps pipeline hoàn chỉnh với GitHub Actions.

2. Lộ trình học tập & Yêu cầu

Tuần	Chủ đề	Sản phẩm nộp
1–2	Lập trình an toàn & OWASP Top 10	YC1: Chứng chỉ Semgrep + Bài phân tích UniMart (1–2 trang)
3–4	Threat Modeling, attack & defend Viết mã khai thác chứng minh	YC2: Ảnh chụp PortSwigger (7 labs) + Juice Shop (10 challenges)
5–6	Phân tích mã nguồn tĩnh (SAST) & Rà soát mã nguồn	YC3: Báo cáo so sánh Semgrep vs SonarQube
7–8	Quản lý mã nguồn (Git) & CI/CD	Không có sản phẩm nộp riêng
9–10	Xây dựng quy trình DevSecOps	YC4: GitHub repo chứa pipeline hoàn chỉnh
11–12	Đồ án cuối kỳ	Đồ án (50%): Báo cáo PDF + GitHub repo

Lưu ý: Khóa học trên Semgrep Academy sử dụng chuẩn OWASP Top Ten 2017, cần chủ động đối chiếu phiên bản OWASP Top 10 năm 2025 mới nhất trên owasp.org.

Hướng dẫn chi tiết từng tuần

Tuần 1–2: Lập trình an toàn & OWASP Top 10

Mục tiêu: xây dựng nền tảng lý thuyết về bảo mật phần mềm — tìm hiểu lỗ hổng phổ biến nhất và các nguyên tắc thiết kế hệ thống an toàn.

- **Semgrep Academy:** Hoàn thành khóa Secure Coding trên <https://academy.semgrep.dev/courses/secure-coding>.
- **OWASP Top 10:** Đọc tài liệu gốc về 10 lỗ hổng bảo mật web phổ biến nhất tại owasp.org/www-project-top-ten/.
- **Saltzer & Schroeder:** Đọc bài báo gốc "[The Protection of Information in Computer Systems](#)" (1975) về 8 nguyên tắc thiết kế bảo mật.

- **Tài liệu bổ sung:** [OWASP Cheat Sheet Series](#).

Sản phẩm nộp: Chứng chỉ Semgrep Academy + bài viết phân tích 8 nguyên tắc Saltzer & Schroeder trên ứng dụng giả định UniMart (1–2 trang, xem tài liệu đính kèm).

Tuần 3–4: Threat Modeling, Attack & Defend

Mục tiêu: học cách tư duy như kẻ tấn công thông qua Threat Modeling, và trực tiếp khai thác lỗ hổng trên ứng dụng thực hành.

- **Mô hình hóa mối đe dọa:** Đọc [OWASP Threat Modeling Cheat Sheet](#). Tìm hiểu phương pháp STRIDE, phân loại mối đe dọa theo 6 nhóm: Giả mạo danh tính (Spoofing), Sửa đổi dữ liệu (Tampering), Chối bỏ hành vi (Repudiation), Rò rỉ thông tin (Information Disclosure), Từ chối dịch vụ (Denial of Service), Leo thang đặc quyền (Elevation of Privilege).
- **PortSwigger Academy:** Hoàn thành 7 bài lab mức Apprentice (người mới) tại portswigger.net/web-security. Chọn lab thuộc chủ đề: Chèn mã SQL (SQL Injection), Tấn công kịch bản chéo trang (XSS), Giả mạo yêu cầu phía máy chủ (SSRF), và Lỗi xác thực (Authentication).
- **OWASP Juice Shop:** Cài đặt bằng Docker, hoàn thành 10 thử thách mức 1–3 sao. Juice Shop là ứng dụng web cố tình chứa lỗ hổng, dùng để thực hành khai thác an toàn.
- **Công cụ:** Sử dụng Burp Suite Community hoặc OWASP ZAP làm proxy chặn bắt để quan sát và chỉnh sửa yêu cầu HTTP.

Sản phẩm nộp: Ảnh chụp màn hình tiến độ PortSwigger (7 labs) + Juice Shop Score Board (10 challenges).

Tuần 5–6: Phân tích mã nguồn tĩnh (SAST) & Rà soát mã nguồn

Mục tiêu: học cách sử dụng công cụ quét mã nguồn tĩnh để tìm lỗ hổng mà không cần chạy ứng dụng.

- **Semgrep:** Hoàn thành khóa Semgrep 101 trên academy.semgrep.dev. Cài Semgrep CLI bằng `pip install semgrep`, quét 1 repo chứa lỗ hổng, và tự viết 2 luật quét tùy chỉnh (custom rules).
- **SonarQube Cloud:** Kết nối GitHub repo với sonarcloud.io để quét tự động. Tìm hiểu Dashboard và Quality Gate.
- **SonarLint:** Cài plugin cho VS Code hoặc IntelliJ để nhận phản hồi bảo mật ngay khi viết mã.
- **Tài liệu bổ sung:** [OWASP Code Review Guide](#).

Sản phẩm nộp: Báo cáo so sánh Semgrep vs SonarQube trên cùng 1 repo: kết quả quét, true positive vs false positive, nhận xét ưu nhược.

Tuần 7–8: Quản lý mã nguồn Git & CI/CD

Mục tiêu: nắm vững Git và thiết lập quy trình CI/CD.

- **Git cơ bản:** Nắm vững: clone, tạo nhánh (branch), lưu thay đổi (commit), gộp nhánh (merge), gửi yêu cầu gộp mã (pull request). Thực hành giải quyết xung đột gộp (merge conflict) và viết thông điệp commit theo chuẩn Conventional Commits.
- **GitHub Flow:** Hiểu quy trình phân nhánh: tạo nhánh tính năng (feature branch) → commit → mở Pull Request → rà soát mã (code review) → gộp vào nhánh chính (main).
- **GitHub Actions:** Đọc tài liệu docs.github.com/actions. Hiểu cấu trúc: workflow, job, step, runner. Tự tạo 1 workflow đơn giản: khi push, tự động chạy kiểm tra.
- **Thực hành:** Fork 1 repo mẫu (ví dụ: ứng dụng Flask/Node.js nhỏ), tạo workflow chạy unit test tự động khi có Pull Request.
- **Tài liệu:** [GitHub Skills](#), hoàn thành module "Introduction to GitHub" và "Hello GitHub Actions".

Ghi chú: Môn học dùng GitHub Actions vì dễ tiếp cận. Trong doanh nghiệp, Jenkins là nền tảng CI/CD phổ biến nhất, khuyến khích tự tìm hiểu thêm tại jenkins.io.

Tuần này không có sản phẩm nộp riêng. Kiến thức Git & CI/CD là nền tảng cho Yêu cầu 4.

Tuần 9–10: Xây dựng quy trình DevSecOps

Mục tiêu: tích hợp bảo mật vào quy trình phát triển: xây dựng pipeline tự động quét bảo mật hoàn chỉnh bằng GitHub Actions.

- **Xây dựng pipeline:** Tạo workflow gồm: Build → Quét mã nguồn tĩnh bằng Semgrep + SonarQube (SAST) → Kiểm tra lỗ hổng thư viện bằng Snyk/Dependabot (SCA) → Quét ứng dụng đang chạy bằng OWASP ZAP (DAST).
- **Quality Gate:** Thiết lập Quality Gate tự động báo fail nếu phát hiện lỗ hổng high/critical.
- **Thực hành:** Sửa lỗ hổng → chạy lại pipeline → đảm bảo pass.

Sản phẩm nộp: Link GitHub repo chứa workflow DevSecOps hoàn chỉnh, chứng minh pipeline pass sau khi sửa lỗi.

Tuần 11–12: Đồ án cuối kỳ

Tổng hợp toàn bộ kiến thức vào dự án thực tế. Chọn 1 repo chứa lỗ hổng từ danh sách gợi ý (khuyến khích chọn từ tuần 5–6). Quy trình:

- **Bước 1:** Threat Modeling bằng STRIDE.
- **Bước 2:** Quét mã nguồn tĩnh bằng Semgrep + SonarQube (SAST).
- **Bước 3:** Rà soát mã nguồn thủ công, chỉ ra tối thiểu 3 lỗ hổng.

- **Bước 4:** Viết mã PoC (Proof of Concept).
- **Bước 5:** Xây dựng pipeline DevSecOps (có thể tái sử dụng từ Yêu cầu 4).
- **Bước 6:** Sửa lỗi bảo mật và viết báo cáo.

Sản phẩm nộp: Báo cáo PDF (10–20 trang) + GitHub repo chứa pipeline. Chi tiết xem mục 4.

3. Quy định Đánh giá & Chấm điểm

Thành phần	Tỷ lệ điểm
Yêu cầu 1: Semgrep cert + báo cáo	10%
Yêu cầu 2: PortSwigger + Juice Shop	15%
Yêu cầu 3: Báo cáo Semgrep vs SonarQube	10%
Yêu cầu 4: DevSecOps Pipeline	15%
Đồ án cuối kỳ (Báo cáo + Repo + Demo)	50%

Quy định nộp bài: Nộp trễ các báo cáo sẽ bị trừ 10% số điểm của yêu cầu đó cho mỗi tuần trễ hạn.

4. Hướng dẫn đồ án

Các bạn có thể làm **cá nhân hoặc lập nhóm tối đa 2 người**. Hãy chọn 1 repo chứa mã nguồn có lỗi tiềm ẩn từ danh sách được cung cấp. Có thể tái sử dụng pipeline từ Yêu cầu 4 và điều chỉnh cho phù hợp với repo đồ án.

Sản phẩm bắt buộc phải nộp:

1. **Báo cáo (PDF, 10–20 trang):** Phải bao gồm Threat Model (STRIDE), kết quả quét SAST bằng Semgrep và SonarQube, Manual Code Review chỉ ra tối thiểu 3 lỗ hổng, PoC khai thác và các khuyến nghị khắc phục (ảnh chụp màn hình).
2. **GitHub repo:** Chứa source code ứng dụng, DevSecOps pipeline cấu hình bằng GitHub Actions, kết quả tự động scan và các commit fix lỗi bảo mật.

Tiêu chí chấm điểm:

- Threat Model đầy đủ, logic hợp lý: **10%**
- Phân tích SAST (Semgrep + SonarQube) chất lượng, có nhận xét về false/true positive: **10%**
- Manual Code Review kết hợp PoC khai thác thành công: **10%**
- DevSecOps Pipeline hoạt động trơn tru (Gồm SAST, SCA, DAST, Quality Gate): **10%**

- Đưa ra khuyến nghị fix lỗi đúng đắn và demo pipeline pass sau khi fix: **5%**
- Báo cáo trình bày đẹp, rõ ràng, chuyên nghiệp: **5%**

Yêu cầu xây dựng DevSecOps Pipeline

Các bạn sẽ dùng GitHub Actions để tạo một workflow đi qua các stages (bước) sau:

- **Code Commit:** Khi có push hoặc Pull Request (PR) sẽ tự động trigger workflow.
- **Build:** Cài đặt các dependencies cần thiết cho dự án.
- **SAST:** Quét bằng Semgrep và phân tích qua SonarQube Cloud.
- **SCA:** Dùng Snyk hoặc Dependabot để kiểm tra các lỗ hổng CVE trong các thư viện (dependencies).
- **DAST:** Dùng OWASP ZAP để quét ứng dụng khi đang chạy (nếu mô hình ứng dụng cho phép).
- **Quality Gate:** Pipeline phải báo fail và chặn việc deploy nếu phát hiện lỗ hổng mức độ high hoặc critical.

Lưu ý: Không phải mọi loại dự án đều cần phải ép đủ cả 4 loại scan. Ví dụ: Một repo về firmware/IoT có thể chỉ cần chạy SAST và SCA. Quan trọng là các bạn **phải giải thích được lý do tại sao lại chọn hoặc bỏ** các stage đó trong bài báo cáo của mình.

Công cụ & Môi trường cần cài đặt

Các bạn hãy chủ động chuẩn bị môi trường trên máy tính cá nhân bao gồm: Docker, Git, VS Code hoặc IntelliJ, và Python 3.x.

- **Học tập & Thực hành:** Semgrep Academy (academy.semgrep.dev), PortSwigger Academy (portswigger.net/web-security).
- **Công cụ Scan:** Semgrep CLI (`pip install semgrep`) hoặc Cloud (<https://semgrep.dev/>), SonarQube Cloud (sonarcloud.io), SonarLint (Plugin IDE), OWASP ZAP (zaproxy.org), Snyk (snyk.io).
- **Proxy/CI-CD:** Burp Suite Community, GitHub Actions.

Danh sách Repo Vulnerable tham khảo cho đề án

Môn học không giới hạn ở các ứng dụng Web, khuyến khích các bạn thử sức với API, Mobile, Thick client, CI/CD, Cloud, IoT, hoặc AI/LLM. Hãy chọn 1 repo phù hợp với kỹ năng và sở thích của bản thân:

- **Web:** [OWASP Juice Shop](#) (Node.js), [WebGoat](#) (Java).
- **API:** [VAmPI](#) (Python/Flask), [Damn Vulnerable RESTaurant](#) (Python).
- **Mobile:** [DIVA Android](#) (Java), [Damn Vulnerable Bank](#) (Kotlin).
- **Thick Client:** [VuCSA](#) (Java).
- **CI/CD & Cloud:** [CI/CD Goat](#) (Docker), [Kubernetes Goat](#) (K8s), [TerraGoat](#) (Terraform).
- **IoT & Firmware:** [OWASP IoT Goat](#), [DVRF](#).

- **Secrets & AI:** [OWASP WrongSecrets](#) (Java), [Damn Vulnerable LLM](#) (Python).